Assignment 6 - Managing Supply Chain and Vendor Risks for CMMC Compliance

Develop a structured approach to manage third-party and subcontractor cybersecurity risks while ensuring alignment with CMMC flow-down requirements.

Instructions:

In this exercise, you'll simulate how to manage cybersecurity risks that come from vendors, suppliers, and subcontractors. The focus is on applying risk assessments, vendor vetting procedures, and contract flow-down requirements aligned with your targeted CMMC level.

You will review the scenario and answer practical questions to build your understanding of how to ensure compliance beyond your own organization.

Scenario:

Your company relies on:

- A managed IT services provider for helpdesk and system patching
- A cloud file-sharing service used by staff for CUI
- Two subcontractors developing components for a DoD project

You are targeting **CMMC Level 2**, and must ensure all third parties maintain acceptable security standards and meet applicable flow-down obligations.

However, one subcontractor has not signed a cybersecurity clause. The cloud service does not provide FedRAMP Moderate certification. And you've never conducted a vendor risk assessment before.

Questions for this assignment

Tasks:

1. What minimum cybersecurity criteria should be included in third-party contracts?

2. How do you assess vendors' alignment with CMMC requirements?

3. What actions will you take if a vendor lacks compliance documentation?

4. How will you monitor subcontractor security post-engagement?

5. Describe your flow-down process for CMMC clauses.

Solution by the Instructor:

Tasks:

1. What minimum cybersecurity criteria should be included in third-party contracts?

2. How do you assess vendors' alignment with CMMC requirements?

3. What actions will you take if a vendor lacks compliance documentation?

4. How will you monitor subcontractor security post-engagement?

5. Describe your flow-down process for CMMC clauses.

Sample Solution:

1. Contracts should include access control, incident reporting, encryption, and audit cooperation terms.
2. Use a vendor questionnaire covering CMMC-relevant domains, verify certifications (e.g., SOC 2, FedRAMP).
3. Enforce deadlines to meet security controls or find replacements.
4. Require quarterly compliance updates and annual audits.
5. Include specific CMMC level obligations in every subcontract and track acknowledgment signatures.